

Mitigating Risks Across the Life Cycle of Generative Artificial Intelligence

Mark Maybury

Vice President, Commercialization
Technology and Strategic Innovation, Lockheed Martin
Chelmsford, MA 01824 USA
mark.t.maybury@lmco.com

Abstract

Rapid adoption of Generative AI and agents across multiple use cases promises productivity, precision, and progress across a range of critical missions. While Large Language Models (LLMs) and agents promise significant value [Guo et al. 2024], they introduce individual and organizational risks that require mitigation while navigating a complex and evolving set of technologies. Building on prior research on LLM vulnerabilities which can undermine confidentiality, integrity, and availability, this paper presents a unified framework for countermeasures to a range of risks and associated harms across the systems development life cycle. Following an assessment of threats and real-world cases, we present essential methods and measures to help mitigate risks across the life cycle and point to future research.

1 Introduction

This paper begins by considering risks across the life cycle from requirements to development to test to deployment to operation and maintenance through decommissioning of generative AI systems. Specializing broad threat frameworks such as NIST's AI Risk Management Framework (RMF) [2023, 2024] and MITRE's [2025] ATLAS, this paper offers a life cycle focused set of proven mitigations and measures across confidentiality, integrity and availability risks. We provide a framework for characterizing harms associated with real-world generative AI risks and mitigations with measures to assess key elements of risks. We summarize the implications of these for individuals and organizations when managing generative AI responsibly and point to important future directions for research.

2 Risk Across the Generative AI Life Cycle

Figure 1 exemplifies threats to generative AI across the life cycle. We classify these in terms of classical risk management framework [NIST 2023, 2024; MITRE 2025] considerations of ensuring confidentiality, integrity, and availability but from a comprehensive perspective of the software systems development life cycle. Figure 1 also identifies the specific assets (data, software, process, people) targeted by adversaries during each stage of generative AI development.

2.1 Requirements

One of the foundational threats to generative AI is the failure to consider the need for protection in the first place. Given an increasing number of high profile attacks and failures, it is imperative to establish requirements up front and manage them throughout the life cycle to mitigate risk. As summarized in the first row of Figure 1, in terms of confidentiality, establishing legitimate versus unauthorized users of LLMs is essential to ensure that private, proprietary and confidential data is protected at rest, during processing, and in transit. In terms of integrity, it is important that requirements capture the policy and procedures necessary to ensure appropriate attention is placed on the quality of data, models, APIs, and generated outputs to ensure their pedigree and legitimacy, accuracy (including such measures as precision and recall). They should also include appropriate representations of degree of confidence in generated information and/or recommendations. This is necessary to ensure users dynamically calibrate the appropriate level of trust of the system for various low- to high-risk use cases to avoid over- or under-trust. In terms of availability, requirements should capture appropriate access and use to include speed, timeliness of responses, redundancy, and continuity or self-recovery to ensure appropriate levels of usability and resilience.

	Confidentiality	Integrity	Availability	Asset Targeted
Requirements	- Insufficient authorization and disclosure requirements - Insufficient data storage, processing, transmission protection	- Insufficient requirements for accuracy, confidence and trust - Insufficient testing requirements and KPIs	- Insufficient requirements for appropriate access and use - Flawed DoS testing requirements	- Requirements Documentation - Specifications for data, model or algorithms - Third party supplier tools and information
Design & Development	- Release of confidential or proprietary information - Release of PII or PHI	- Biased data/development teams - Poisoning/corrupting real or synthetic training data - Corrupting models or tools	- Degradation of key resources - Denial of resources - Damage or destruction of resources	- Training or synthetic data and models - PII, PHI data - Third party tools and resources
Test	Unauthorized access to test data/scripts or API tests	- Incomplete testing - Corruption of testing	Denial of test data or test resources	- Test data/scripts/APIs - Testing models and tools
Deployment	- Unauthorized access (e.g., jailbreaking, proxy intermediary) - Reverse engineering	- Insufficient guardrails - MCP or proxy attack - Exploiting weaknesses during inference	- Denial of service - Holding data or models for ransom	- Prompts, inference - MCP or intermediary proxies - Data and models - Guardrails
Operation & Maintenance	- Deep fakes - Generative AI cyber scans at speed & scale - Social engineering (speed, scale, high-fidelity)	- Model drift from prompts - Disinformation at speed and scale - MCP or proxy attack - Corruption of third-party information, code	- Extremely high-fidelity email, chat, web site, call center flooding at speed and scale - Erosion of confidence	- Data and models - Target systems - Employees via Social engineering - Third party data, code, services - Users (confidence and trust)
Decommission	- No data/model destruction - Disclosure end of service	- Use of retired data/model - Corruption of new with old	- Continued access - Lack of rights revocation	Data/Models/Tools/Compute

Figure 1. Life Cycle Threats Against Generative AI Assets

Finally, requirements should articulate the relevant criticality of resources (e.g., data vs. model vs. infrastructure) across life cycle stages. They should also distinguish the relative degree of importance of various requirements for confidentiality, integrity and availability, such as those that are necessary (e.g., statutorily required) versus desired (e.g., recommended practices) versus optional needs. Requirements may suggest how

these are to be realized, for example as high level policies, operational procedures, user training, or technical controls/guardrails as well as consequences or penalties for failure to satisfy them. Notably, requirements artifacts themselves are a target of adversaries given specification and supplier insights.

2.2 Design & Development

An important threat to generative AI occurs during system design and development. During this critical phase, the confidentiality of training data remains paramount. This includes private information such as personally identifying information (PII), personal health information (PHI), confidential information (e.g., business information), or proprietary information (e.g., trade secrets, source code). The integrity of that same training is equally important. A well-known concern because of multiple prior failures is the risk of biased output, which can be a self-inflicted risk if the data or development team lacks sufficient diversity. In addition, insufficiently robust training data sets are more vulnerable to data corruption and/or poisoning of data. In one example, corruption of only 1% of an image classifier's tuning data resulted in image classification errors of 80% across four LLMs [Zhou et al. 2024]. Related, as few as 250 documents during fine-tuning can compromise even the largest models. In addition, if adversaries have direct access to real or synthetic training data or models or third party tools and resources, they can subtly degrade or destroy them.

Finally, developers can suffer from availability threats during development to include denial, damage, or destruction of essential training resources which can include data, tools, infrastructure, and power. For example, the ShadowRay 2.0 [2025] attackers exploited a vulnerability in the Ray AI framework, used by AI developers to hijack 200,000 GPUs servers for cryptojacking affecting biopharma, education and finance. In another attack, AWS keys were stolen to call foundational model APIs for unauthorized use of Claude 3 Opus costing \$100,000 a day [Sysdig 2024].

2.3 Test

One of the most critical risk mitigation steps for generative AI is system test and evaluation. This means balancing the benefits of disclosure (e.g., peer review, community progress) with confidentiality of test data and assessment tools which could be used by adversaries to identify vulnerabilities with data, models, and outputs. An LLM "bug bounty" program would be a valuable mechanism to foster controlled disclosure. An important threat to integrity is self-imposed, in particular testing that is incomplete and not comprehensive by failing to address known attacks or failing to anticipate likely future ones. This argues for sharing known threat vectors (e.g., bias or hallucination) and developing shared test data and tools that address those threats, at the same time protecting against the corruption of training data or test suites. Finally, as with development, denial of access to test data or test resources, internal or third party, self-imposed or by an active adversary, poses an availability risk.

2.4 Deployment

During large language model deployment, several threats exist across confidentiality, integrity and availability. These include

unauthorized access to personal, confidential or proprietary information by proxy intermediaries. Proxies sit between users and LLMs and route requests raising opportunities for man in the middle attacks, indirect prompt injections, and theft of aggregated credentials. Direct prompt-injection attacks can jail-break models and expose sensitive data, e.g., by masquerading as an authorized user. In addition, adversaries may aim to reverse engineer training data from models by massively querying and building a digital twin model based on inputs and outputs, or by inferring or tricking release of model weights.

In terms of integrity, insufficient guardrails can enable adversaries to engineer prompts that release misleading, low confidence or even hallucinated responses. In addition, adversaries with deep understanding of the models and their training data can exploit weaknesses, such as bypassing integrity checks or manipulating the inference process. They can also attack external interfaces such as data, file, tool or model proxies or Model Context Protocol [MCP 2025]. Finally, availability of systems can be undermined through a range of denial of service attacks (e.g., flooding) or by extracting and holding data or models for ransom.

2.5 Operations and Maintenance

Once an LLM is fully operational, it is subject to a number of malicious acts. These can include misuse of the model to undermine confidentiality, such as model inversion to extract PII such as passwords, addresses, and account numbers [Carlini 2023, Sivashanmugam 2025]. Personal data in LLMs can also enable actors to create deep fakes for a variety of nefarious purposes (e.g., identity fraud, reputational attacks, disinformation). This is particularly problematic because deep fakes are increasingly challenging for humans to identify. In one study, up to 50% of users were unable to distinguish real from counterfeit [Doss et al. 2023]. Semantic Forensic (SemaFor) integration of automated methods enhances deep fake detection [Keller, 2021]. Generative AI can also enable attacks on user credentials and sensitive information by enabling cyber scans at speed and scale. Combined speed, scale, and high-fidelity was recently illustrated in the use of Claude Code and Model Context Protocol (MCP) to semi-automate an attack on approximately thirty global companies attributed to a nation state cyber actor [Anthropic 2025]. Finally, because of the exquisite and real time knowledge access provided by LLMs, threats from social engineering are democratized and scalable.

In addition to confidentiality challenges, threats to integrity abound. This includes adversaries injecting prompts to bypass guardrails or use language to drive undesirable outputs. This occurred when a crafty customer injected prompts into a Chevrolet [2023] dealership's ChatGPT based chatbot to trick it to offer a 2024 Chevy Tahoe for \$1. In addition, adversaries can use these tools to operationally attack the integrity of underlying data by rapidly creating large scale disinformation. By directly corrupting third-party information and/or underlying code bases or external dependencies (e.g., via MCP), adversaries can threaten system integrity during operations.

Finally, availability of LLMs are potentially threatened by the very use of LLMs to rapidly and massively generate extremely high-fidelity email, chat, website, or audio conversations to flood services such as call centers or e-commerce sites. In contrast, if system integrity is degraded, that could result in

a cease and desist order or simply an erosion of user confidence that could directly or voluntarily shut down the service.

2.6 Decommissioning

Adversaries can exploit LLMs even after decommissioning by targeting any unprotected data, models, tools, and compute infrastructure. Threats include confidentiality attacks because data or models were not destroyed or had insufficient non-disclosure protection at end of life. Integrity threats can occur unintentionally if developers unknowing use retired data or models or intentionally if adversaries corrupt new data or models with decommissioned old ones. Finally, appropriate non availability can be undermined either by failing to revoke access rights or enabling continued access to denied data or models.

2.7 Summary

Since there are insufficient resources to protect against all possible threats across the life cycle, systems builders will need to take a risk management approach and prioritize across the high risk cases (e.g., risk of LLMs being used to create weapons of mass destruction) and focus on the most likely attack vectors by adversaries. MITRE’s [2023] ATLAS is a valuable resource for defenders to maintain awareness of the emerging threat actors and attack patterns against AI systems. Another challenge will be balancing disclosure of data and evaluation methods to benefit from feedback and foster development of community best practices with the need for confidentiality and operational assurance. Here “bug bounties” for LLMs could provide value.

Finally, given that training data and machine learned models are perhaps the most valuable piece of intellectual property for generative AI, ensuring their confidentiality, integrity and availability remains paramount. Equally, as models increase in capability, organizations will need to continuously monitor and evolve policy, technology and training to mitigate risk using the best mix of human and agent capability.

3 Risks, Harms, Mitigations and Measures

Generative AI systems suffer from underlying model weaknesses including biased, brittle, and baroque (highly complex and opaque) LLMs resulting in weaknesses in confidentiality, integrity, and availability [Maybury 2025]. Insufficiently diverse training data can result in *biased* LLMs which can generate prejudiced or discriminatory output. Because LLMs are machine learned, statistically-based token predictors, they are *brittle* and can produce false positives or false negatives, and are vulnerable to data poisoning [Zhou et al. 2024], prompt injection and jailbreaking (disclosure) attacks [Andriushchenko, et al. 2024]. Independent assessments of leading LLMs report hallucination rates in 3-24% of responses [GitHub 2025]. Finally, their massive, multilayer nature (e.g., GPT-4 has 100 layers and 1 trillion parameters [Albergotti 2023]) make it challenging to clarify reasoning [Bubeck et al. 2023]. This elaborate and opaque or *baroque* nature undermines assurance and integrity as well as human confidence.

It is essential for policy makers, developers, and users alike to understand the common foundation of these systems and associated risks in order to understand potential harms. This can accelerate creation of associated evaluation measures and mitigations to address concerns with models across the life cycle.

Extending previous work on detailed root causes, failure modes, and associated harms of LLMs [Maybury 2025], Figure 2 illustrates in blue boxes the model training, fine tuning and generation process typical of large language models and often employed by agents. The red boxes capture a set of significant risks associated with key steps in the process of model training and generation to include biased data or training, confidentiality and privacy violations, copyright/trademark infringement, misinformation from hallucination or prompt injection, and generation of offensive material. We consider these in turn.

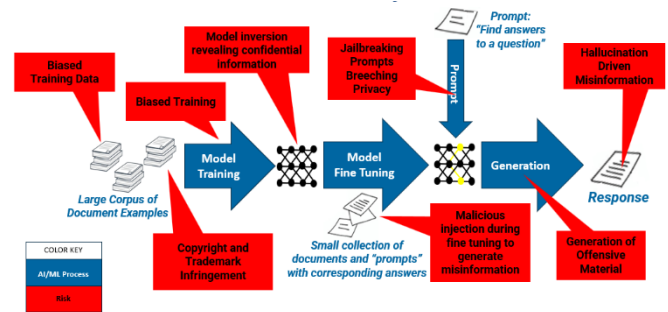


Figure 2. Risk to Generative AI Across the Life Cycle

3.1 Unauthorized Data Use

There is a growing recognition that LLMs can harm creators or data owners in several ways as summarized in the top row in Figure 3. These include but are not limited to loss of income by training or generating text, images or audio without consent or compensation to the original authors; dilution of trademark or brand when a model reproduces recognizable logos or stylistic signatures; and enablement of reverse-engineering of proprietary works, exposing trade-secrets or distinctive artistic techniques. Copyright issues are the basis of multiple lawsuits. For example, on September 2025 a federal judge granted preliminary approval for Anthropic to pay \$1.5B to authors for pirated books [Ortutay 2025].

Some mitigations are summarized in the second column in the top row of Figure 3. For example, training datasets should consist only of publicly-licensed, public-domain, or explicitly-licensed content. Data-provenance should be tracked robustly and “safe-harbor” filtering should block generation of protected content. Digital watermarks, provenance metadata, or other traceable signals in AI-generated assets enable downstream platforms to automatically identify and enforce appropriate usage policies. Also, data users should pursue informed consent and fair compensation (e.g., royalty or revenue-sharing) to rights holders. Finally, output should be continuously monitored for potential violations. A final column in Figure 3 describes quantitative measures for these such as financial harm to property owners, the number of unauthorized sensitive data releases, and the mean time to detect data exfiltration.

3.2 Privacy

AI-driven conversational agents which are typically enabled by LLMs present a risk for data-privacy violations as discussed previously and summarized in row 2 of Figure 3. When these systems ingest, store, and process personally identifiable information (PII) (e.g., names, identity numbers, date of birth), personal healthcare information (PHI) or biometric identifiers

(e.g., facial images, voice prints, fingerprints), this requires written consent. Risks include potentially exposing users to unauthorized profiling, identity theft, and discrimination. Consequences of infractions can include fines, punitive damages, and injunction.

Category	Example Harms	Example Mitigations	Key Harm Indicators
Unauthorized Data Use	- Unauthorized use for training and generation - Loss of income and control to rights owner - Enables Reverse engineering	- Avoid use (in training or generation) of unauthorized data - Consent (pub domain, license) - Compensate (royalty, rev share) - Digital watermarks, provenance metadata - Audit output continuously	- Financial harm to IP owners - Mean time to detect exfiltration attempt - Number of unauthorized release incidents
Privacy Breach	- Unauthorized use of private/biometric data - Release of PII or PHI	- Ensure data consent and provenance - Deidentification - Access controls, Opt-In Watermark/Metadata	% Prompts triggering breaches - Mean time to detect a privacy breach
Misinformation/Disinformation	- Hallucination of false claims - Misreporting info/events	- Fact checking, RAG, Content/language filtering - Human review, audit trails	- Response Precision and Recall % Hallucination - False-positive rate of content filtering
Bias	Biased algorithmic decisions	- Data Diversity - Bias Measurement across life cycle - Human review/approval	% of biased responses % auto vs. human detected across the life cycle - Bias disparity across groups

Figure 3. Example Harms and Mitigations

As summarized in Figure 3, risk mitigation can include implementing a rigorous data-governance framework that (1) restricts training and inference datasets to sources with verified consent and documented provenance, (2) applies robust de-identification or differential-privacy techniques [Patil et al. 2023] to strip personally identifiable and biometric attributes prior to model ingestion, (3) enforces granular role-based access controls and audit trails for any residual sensitive data as well as watermarking to detect leaks, and (4) adopts an explicit opt-in mechanism, with clear disclosures, ensuring that users affirmatively authorize the capture and use of biometric information before it is used by any AI training process. Instituting safeguards not only aligns systems with prevailing statutory mandates but also reduces exposure to costly litigation and reputational damage. The frequency and speed of breeches are example quantitative measures to assess harms.

3.3 Misinformation and Disinformation

As summarized in row 3 of Figure 3, generative-AI platform risks include both misinformation (unintentional errors such as hallucinations) and disinformation (intentional misreports or misrepresentation such as by a deep fake). Recent failures included Australian mayor-candidate Brian Hood sending notice to OpenAI for allegedly fabricating false statements about his conduct [Gerken 2023], Robert Starbuck’s claim against Meta that a hallucinated output mischaracterized him as participating in the January 6, 2021 Capitol attack [Starbuck v. Meta 2025], and the congressional effort led by Sen. Marsha Blackburn [2025] to force the removal of Google’s Gemma model on the basis that its responses disseminated defamatory content. These examples illustrate that AI-generated narratives can damage personal reputations or consumer brands, erode stakeholder trust, and trigger litigation. Tangible harms range from immediate reputational injury and loss of consumer confidence to financial penalties, including statutory damages, corrective-notice obligations, and downstream contract breaches.

Risk mitigation can include instituting a multilayered governance framework that enforces and measures (1) content-filtering controls anchored in verified fact-checking databases,

(2) real-time, domain-specific classifiers to flag potentially defamatory language, (3) structured human-in-the-loop review for public disseminated output (e.g., content about individuals, corporations, or politically sensitive topics), and (4) comprehensive audit trails that capture model prompts, generated responses, and reviewer decisions for evidentiary defensibility. By coupling automated safeguards with rigorous editorial oversight, organizations can substantially reduce the likelihood of inadvertently publishing false or injurious statements and limit exposure to both financial and reputational repercussions.

3.4 Bias

Algorithmic decision-making represents a very broad opportunity for risk given AI-driven hiring, housing, and insurance tools may produce disparate impact or disparate treatment of protected classes. For example, in *Mobley v. Workday* [2025], Workday’s AI platform for HR, used by over 11,000 organizations around the world to rank job applicants, denied over 100+ applications by Derek Mobley, a disabled, black candidate over 40. The court decided the case could proceed as a class action and recognized Mobley’s claim as plausible under the Age Discrimination in Employment Act (ADEA). Harms of algorithmic bias include exclusion of qualified candidates, denial of housing or coverage, and the perpetuation of systemic inequities, which can trigger statutory damages, injunctive relief, and class-action exposure under the Civil Rights Act, the Fair Housing Act, and state anti-discrimination statutes.

As summarized in the final row of Figure 3, exposure mitigations include (1) curating training datasets that reflect the full diversity of the relevant population and remove proxy variables for protected attributes; (2) implementing rigorous bias-measurement protocols (e.g., disparate impact analysis, subgroup performance monitoring, and counterfactual fairness testing) both during model development and deployment; and (3) embedding mandatory human review for any high-stakes decision, complemented by transparent documentation of model provenance, impact assessments, and remediation procedures. Integrating controls to comply with anti-discrimination requirements promises to reduce the likelihood of discriminatory conduct.

3.5 Unequal Access

As the top row of Figure 4 addresses, fair access to these powerful tools is important not only for equity but also for fostering innovation and broad adoption. A recent lawsuit filed by X (formerly Twitter) and its owner, Elon Musk, against OpenAI and Microsoft [X Corp 2025] alleges the defendants’ API pricing, data-access policies, and bundled cloud services constitute an unlawful abuse of market power. When a single AI provider controls the bulk of high-quality training data, proprietary model architectures, and inference infrastructure, it can erect de-facto barriers to entry, compel downstream developers to accept exclusive licensing terms, and enable price-discriminatory or practices that trigger violations of the Sherman Antitrust Act and related competition statutes. Harms can include erosion of fair competition, monopolistic market positions (analogous to prior enforcement actions against operating-system and cloud providers) with exposure to multi-billion-dollar civil penalties, injunctive relief, forced divestitures, and reputational damage.

Category	Example Harms	Example Mitigations	Key Harm Indicators
Unequal Access	- Closed architectures inhibiting innovation - Unfair competition and/or pricing	- Open architectures and standards-based APIs - Reasonable and nondiscriminatory (RAND) licensing and pricing - Independent audits	- Number of inequity incidents detected by independent audit over time - Financial harms
Safety	- Financial loss - Physical damage to people or property	- Data, Model, Output Integrity - Rigorous Safety testing - Guardrails (e.g., age-appropriate services) - Human oversight/monitoring - Wellness breaks/throttles	# and severity of near misses and incidents - Financial Losses - Physical harms
Security	- Confidentiality failures - Integrity failures - Availability failures	- Cybersecurity controls - Red teaming - Training Data/Gen Review - Human oversight/monitoring	- Number and severity of failures in C, I, A - Time to detect and correct failures

Figure 4. Mitigations for Generative AI Risks

As noted in the top row of Figure 4, strategies to foster more equitable access include emphasizing open-architectures such as open model APIs, interoperable data-exchange, enabling third-party plug-ins, and offering non-exclusive, transparent licensing and pricing such as is often done with minimal essential patents offering reasonable and nondiscriminatory (RAND) licensing. Complementary safeguards include routine impact assessments, independent algorithmic audits, robust data-portability mechanisms, and proactive engagement to create a level-playing field and pre-emptively addressing practices to foster competition, adoption, and innovation. Measures such as the number of inequity incidents over time and their financial harms are example performance indicators.

3.6 Safety

AI-enabled products introduce risk exposure because a defect in the underlying training data, model, or recommendation algorithm can generate faulty, negligent, or dangerous information and actions that translate directly into financial loss, physical injury, or malpractice claims (e.g., AI-facilitated self-harm, assisted suicide, erroneous medical diagnoses or financial advice, biased employment screening).

Given these exposures, developers and operators must institute rigorous safety-testing regimes (including adversarial testing and bias audits) to ensure the integrity of data, model, and output. Externally facing systems such as chatbots must embed technical guardrails such as age-appropriate content filters, usage limits, and mandatory wellness breaks. Enterprises should enforce clear duty-of-care policies, maintain continuous human oversight of high-risk outputs, implement real-time activity monitoring coupled with automated anomaly detection, and usage throttling for excessive use. High impact AI incident response frameworks that codify playbooks of detection, containment, remediation and post-mortem steps for high consequence services have shown 70% reduction in impact from early detection in the inference pipeline [McIlroy-Rowe et al. 2024]. Documenting safety controls and demonstrating proactive risk-management reduces risk and improves risk reduction over time. Key performance indicators include trends of the number and severity of incidents over time and any associated financial or physical damages.

3.7 Security

The final row in Figure 4 addresses security of generative AI. As they are software systems, LLMs inherit all of the vulnerabilities suffered by software systems include risk of failures in confidentiality, integrity, and availability, as well as vulnerabilities specific to LLMs across the life cycle as illustrated in

Figure 1. While that is a challenge, the good news is all of the standard best cybersecurity practices can be applied such as identity management methods (e.g., two factor authentication, role based access) to reduce confidentiality failures. In addition, methods such as software code signing and digital signatures, software bill of materials, cryptographic hashing (checksums), secure build pipelines with automated test, and run-time integrity monitoring can contribute to underlying infrastructure and code integrity. Finally, redundancy, diversity and roll-back/recovery methods foster availability.

In addition to these traditional cybersecurity and software security methods, LLMs require additional controls such as review and monitoring of data and model confidentiality and integrity. For high assurance domains, this includes approaches such as MIT’s [2018] Moral Machine or Astris AI’s [2025] Persistent Environment for AI, Readiness and Learning (PEARL) which leverages operations analysis and domain-specific digital twins and simulation to perform comprehensive test and evaluation in realistic environments and use cases. LLM retrieval augmented generation (RAG), internal self-consistency from principles [Bai et al. 2022], and external critics of LLMs [Mousavi et al. 2023] can mitigate toxicity and hallucination to enhance robustness and mitigate jailbreaks. Furthermore, semi-automated red teaming that takes advantage of LLMs to protect themselves with increasing amounts of automated monitoring will help ensure humans keep up with the scale and speed of these critical tools. Finally, human oversight will remain essential to detect and address risky unanticipated, emergent, and/or adversarial behavior. Key harm indicators include the number and severity of security failures and the latency of their detection and correction.

4 AI Risk Mitigations Across the Life Cycle

Reducing risk in generative AI deployments is most effective when the effort is built into and across the product-life-cycle to comprehensively address the risks against assets outlined in Figure 1. Given the details presented through the paper, we summarize key controls that can be put in place to enhance the confidentiality, integrity, and availability of LLMs. Figure 6 provides that summary across the lifecycle from requirements through to decommission and maps those onto protected assets (e.g., documentation, data, models, tools, processes, people) associated with measurable key harm indicators as described in the previous section.

	Confidentiality	Integrity	Availability	Assets Protected
Requirements	- Authorization and disclosure requirements for data - Data storage, processing, transmission protection - API protection requirements	- Requirements for accuracy, confidence and trust - Quality testing requirements - API protection requirements	- Requirements for appropriate access and use - Rigorous DoS testing reqts - API protections	- Requirements Documentation - Data, model or algorithms specs 3rd party supply dependencies
Design & Development	- SBOM, Signed tools, Encryption - Identity Mgmt, RBAC - Least privilege, immutable logs - Privacy labels - De-identification - Consent and compensation - Red Teaming	- SBOM, Signed tools, Encryption - Identity Mgmt, RBAC - Least privilege, immutable logs - Use-case risk classification - Model cards - Data-quality/diversity/authority - Active monitoring, Sandboxing - Red Teaming	- Use-case risk classification - Resilient architectures - Rate limits, Sandboxing - Red Teaming	- Training or synthetic data and models - PII, PHI data 3rd Party tools and resources
Test	- Logging verification - RBAC to data/scripts	- Logging verification (data, tests) - Human-oversight simulation - Safety-proof/regression tests - Bug bounties	- Logging verification - Redundancy and rate-limit tests - Human-oversight simulation	- Test data/scripts/APIs - Testing models and tools
Deployment	- SBOM checks/Patch Mgmt - SIEM integration - Runtime enforcement/RBAC - Privacy labels/monitoring - Secure/monitored proxies	- SBOM checks/Patch Mgmt - SIEM integration - Runtime enforcement/RBAC - Human oversight	- Patch Mgmt, SIEM integration - Redundancy/rollback - Data/API/Model Eucrow - Insurance/compliance - Human oversight	- Prompts, Inference - MCP or intermediary proxies - Data and models - Guardrails
Operation & Maintenance	- Periodic SBOM refresh/re-sign - Patch management - Incident logs - Privacy consent/revocation - Deep fake detection/protection - Counter adversarial cyber	- Periodic SBOM refresh/re-sign - Patch management - Bias, hallucination, jailbreak, model drift, dis/misinformation monitoring - Incident logs - Human-in-the-loop for high risk	- Incident logs - Human-in-the-loop for high risk - Insurance renewal	- Data and models - Continuous anomaly detection - Data/API/Model Throttling - Incident logs, sandbox inference - Human-in-the-loop for high risk - Users (confidence and trust)
Decommission	- Data/model destruction - End of life non-disclosure	- Retired data/model attestation - Separation of new and old	- Denial of access - Revocation of data rights	Cleansing/destruction Data/Models/Tools/Compute

Figure 6. Mitigations for Generative AI Vulnerabilities

For example, during design and development, confidentiality of real or synthetic training data, models and tools can be significantly assured by rigorous data, model, and software bill of materials (SBOM) tracking, using trusted digital certificates to sign data and tools for provenance attestation, hashes to detect code manipulation, and third party assessment to assure confidence in supply chains [Wang et al. 2025] and systems. Privacy labelling, de-identification, and encrypting data at rest and in transit can help protect confidential information. Identity management such as two factor authentication and biometrics together with role base access and control (RBAC) and immutable logs can enhance access control. Finally, red teaming to detect flaws and ensuring data owners have provided consent and compensation can significantly reduce the risk of confidentiality failure.

As evident in Figure 6, across all phases, traditional cybersecurity tools such as patch management, integration with Security Information and Event Management (SIEM), and software caching can be applied to enhance security and resilience. To address speed, scale and precision of attacks, automation will be essential. For example, real-time rate limiting and cost-aware throttling of data, API, and model access, and design architectures that ensure sandboxed inference and edge-caching as well as learning resilience for confidentiality, integrity, and availability attacks will become increasingly important. Rigorous modelling and simulation to systematically and comprehensively reduce risk using approaches such as the Moral Machine [2018] and PEARL [2025] will be essential for high assurance domains. And while automated generation of adversarial attacks and quantitative evaluation of countermeasures is essential, red teaming and human oversight (including bug bounties) will remain essential safeguards. However, this will increasingly be augmented by AI-assistants for triage and self-consistency checks, the latter leveraging the consistency of unique correct answers to challenging problems that result from distinct reasoning paths [Wang et al. 2022]. Finally, the final phase of the life cycle requires appropriate disposition, for example, of private, confidential, or proprietary data and models upon system sunseting. This requires sensitive data and model deletion, system sanitization, key revocation, and procedures to ensure the confidentiality of sensitive data, the lack of corruption of new models and agents with revoked LLMs, and the termination of access to decommissioned systems.

5 Risk Measurement Framework Evaluation

While verification and validation methods have been suggested in the literature for particular assets at particular stages, previous work has not comprehensively applied assessment across the full life cycle. Our quantitative risk approach (See Figure 7) measures Risk as a product of the Threat, Vulnerabilities, and Consequences in each stage of the life cycle such that $R = f(T \times V \times C)$, where T is a measure of the frequency and average severity of attack [Strom et al. 2020] against the assets exemplified in this paper, V is measured by the vulnerability severity [MITRE 2026], and C is the severity of the consequences, with each variable normalized zero (none) to 1 (highest). Thus if there is no threat or no vulnerability or no consequence, the risk is zero. In contrast, a high degree of threat, vulnerability, and consequence will yield very high risk. Each

of the consequence categories captured in section 3 of Maybury [submitted] detail associated quantitative measures of harms. While some of harms are readily quantified financially (e.g., \$1.5B to authors for pirated books [Ortutay 2025], \$25M extortion from a deep fake [Chen and Magramo 2024]), others are qualitative (e.g., user frustration, loss of reputation) and need to be converted to quantitative form (e.g., loss of revenue from service delays, reduction in stock price). Moreover, the refined weighted risk calculus shown in the bottom of Figure 7 enables the weighting of multiple threat, vulnerability or consequence metrics. For example, this can include a vulnerability measure that is a blending weighting of the known percentage of jailbreaks, hallucinations, and denial of service exploits. Analogously, the consequences of these same vulnerabilities can be measured and weighted based on the model use case (e.g., a high risk use case may have higher consequences for a failure). This quantitative approach enables defenders to identify the greatest risks in the life cycle, by type of harms and by asset, in order to rationally allocate mitigation investments.

$R = T \times V \times C$

Risk (R) = Threat (T) × Vulnerability (V) × Consequence (C) where:

- T** = Threat likelihood from 0 to 1 (e.g., annual incident frequency normalized by severity from incidentdatabase.ai, alternatively ATLAS.mitre.org).
- V** = Vulnerability severity (e.g., jailbreak %, hallucination %, uptime %).
- C** = Consequence weight (e.g., for high-risk use case, C=1.0 for jailbreak and hallucination, 0.8 for latency, 1 for significant harm).

Or this **Weighted Risk Calculus** for a particular model version:

$$R(model) = \frac{\sum(T_i w_i)}{\#Threats} * \frac{\sum(V_m w_m)}{\#Vulnerabilities} * \frac{\sum(C_n w_n)}{\#Consequences}$$

where T_i , V_m and C_n are the measured metrics for T , V , and C features and where w_i , w_m , and w_n are the weights of the T , V , and C features.

Figure 7. LLM Risk Calculus

Figure 8 illustrates the top 5 LLMs assessed using the risk calculus introduced in Figure 1. For simplification of illustration purposes, we have selected only a few measures such as the frequency and severity of jailbreaks to measure the threat, the strength of bias and hallucination guardrails and jailbreak success to measure vulnerability, and a default measure of consequence (where 0 is none, 1 is high) to assess the overall risk (0 low to 1 high) as shown in the right column of Figure 8.

	Threat	Vulnerability	Consequence	Risk
Criteria (normalized 0-1)	T (Threat Likelihood) Incidentdatabase.ai # & severity / yr (e.g., jailbreak, privacy leak, DoS)	Suggested V (Vulnerability) (based on benchmark & guard-rail strength)	Suggested C (Consequence) (business-specific weight)	Resulting Risk Score (example: C = 0.9 for high-impact product)
System 1	0.7 (14/20 (max)); 2.1 Sev (jailbreak, API-key misuse)	0.30 (strong built-in guardrails, low brittleness)	0.90	0.19
System 2	0.35 (7/20); 1.9 Sev (jailbreak)	0.35 (moderate guardrails, some jailbreak success)	0.90	0.11
System 3	0.45 (9/20); 1.8 Sev (MCP abuse)	0.33 (medium guardrails)	0.90	0.13
System 4	0.6 (12/20); 2.0 Sev (Community jailbreak repos)	0.55 (no native guardrails, high brittleness)	0.90	0.30
System 5	0.5 (10/20); 1.9 Sev (jailbreak + cost-drain)	0.50 (basic filter, moderate brittleness)	0.90	0.23

Figure 8. Overall Risk Measurement of the Top 5 LLMs

To exemplify the power of the risk management framework in a current real world application, Figure 9 illustrates a set of metrics with associated quantitative measures, data for which

are publicly available. These metrics in column one with associated quantitative measures in column two cover both the frequency of threats (metrics and measures highlighted in red) in the cybersecurity categories confidentiality, integrity, and availability, as well as quantitative measures of vulnerability. For example, from incidentdatabase.ai we measure the number of attacks by threat actors in terms of jailbreaking with prompt injection, private data leaks, and model theft to assess the degree of threat to confidentiality of models just as we can measure the number of denial of service or cost imposition by intentional overuse or high jacking of a model.

	Threat/Vulnerability Metric	Threat/Vulnerability Measure
Confidentiality	• Prompt Injection to jailbreak • Jailbreak Success • Run time Jail break • Privacy/Data Leaks • Model Theft	• # Prompt Attacks • % Test Success • % Run Time Success • #/year • #/year
Integrity	• Bias • Bias • Hallucination • MultiModal Language Understanding (MMLU) • Ceval • Big Bench	• SS measure where 0 is neutral • % responses including hate speech • % responses hallucinated • % correct responses • % correct responses • % correct responses
Availability	• Resilience to Data Poisoning • Denial of Service (DOS) • Resource Exhaustion • SLA • Latency • Mean time to detect/mean time to repair	• Drop in MMLU % with 5% data poisoning • #/year • #/year • % UpTime • Milliseconds per token • # days

Figure 9. Select Threat and Vulnerability Measures and Metrics

Figure 10 illustrates the application of these to the top 5 most use LLMs illustrating how they have been relatively threatened in the past year and their relative vulnerability for each measure. The criteria or features marked in the column headings in red are threats whereas those shown in black are vulnerabilities, consistent with Figure 3.

6 Overarching Strategy to Mitigate AI Risks

Given LLMs are built and deployed globally with a multiplicity of supply chains in an evolving threat environment and with evolving vulnerabilities, a comprehensive, continuous, system-

centered risk model is necessary. Defenses should agilely respond to evolving adversary capabilities, focus mitigations on the most vulnerable attack surfaces in medium and high risk use cases to protect critical assets using impact measurements to assess progress. Accordingly, Figure 11 provides a holistic strategy for addressing LLM risk. An essential first step is to map AI use-cases to a risk tier (e.g., low, moderate, high) based on quantifying the potential harms to assets, individuals, organizations, or the public in order to determine the strength of necessary controls. For each model, create a model card [Mitchell et al. 2019, Kelley 2009] to record the data sources, preprocessing steps, training/tuning/testing procedures, quantifiable evaluation metrics, known limitations, quantifiable harms, and mitigations for known failure modes.

Next, ensure the training data, model, and infrastructure are secure. Conduct a data-privacy review to confirm the legitimate basis for any personal data used in training, apply “right-to-be-forgotten” where feasible (e.g., data-deletion scripts or retraining pipelines to excise an individual’s records), and document this in the model card. If the system is subject to export control, classify the model under the appropriate schedule (e.g., U.S. EAR, EU Dual-Use), file any needed licenses, and enforce technical controls (e.g., geofencing, API filtering, digital rights management) to block access from sanctioned jurisdictions.

Minimize bias by employing diverse teams and ensuring a diversity of training and tuning data. Conduct and document initial and annual bias and fairness assessments/audits at model release time and annually using proven toolkits [Bellamy et al. 2018; Bird et al. 2020; Wexler 2019]. Record findings, remediation steps, and any residual risk. For high-risk applications, augment internal checks with an independent third-party audit that can certify compliance with any relevant specific risk-based regimes.

Reduce brittleness using a diversity of machine learning methods to minimize precision and recall errors and ground models in authoritative sources using validated ontologies,

	Confidentiality				Integrity								Availability					Threat/Vuln
Criteria/ LLMs	#	Run	#									5%	#					
	Prompt Jail breaks	Jailbreak Test % Success	time Jail break	Privacy/Data Leaks	# Model Theft	Bias SS (0 Neutral)	Bias Hate	% Halluc	MMLU	CEval	Big Bench	Poison %MMLU Drop	# Resource Exhaustion	% SLA UpTime	Latency ms/token	MTTD MTTR days		
System 1	5	0.42%	92%	3		-0.26	3.1%	3-5%	86%	82%	71%	2%	4	4	99.9	55	2 / 4	Lower
System 2	3	1.2%	89%	2		-0.23	4.4%	6%	82%	78%	66%	2.5%		2	99.9	45	2 / 4	Lower
System 3	2	0.95%	85%			-0.24	3.8%	4%	84%	80%	68%	3%	3		99.9	38	1.5 / 3	Moderate
System 4	6	7.9%	60%		3	-0.03	7.9%	12%	73%	70%	55%	10%	3		99.5	8	5 / 7	Higher
System 5	5	2.3%	68%		2	-0.11	6.3%	9%	71%	68%	53%	8%		3	99.5	7	5 / 7	Higher

These five models account for over 80 % of global LLM inference traffic

Number Incidents (incidentdatabase.ai)

Figure 10. CIA Measurement of Top 5 LLMs

knowledge bases, RAG, and self-consistency [Bai et al. 2022; Mousavi et al. 2023] to reduce hallucination and increase model resilience. Educate users to improve prompt specificity and employ guardrails to screen untrue [Lin et al. 2021], dangerous, and deceptive content [Phoung et al. 2024].

Reduce AI baroqueness by transparently disclosing AI-generated output with clear and unambiguous marking (e.g., “Generated by an AI language model”) consistent with wording in local statutes (e.g., the UK [2023] AI Assurance framework, Canada’s AIDA [2022], or Australia’s [2024] AI Regulation Bill). Provide explanations (e.g., reasoning paths/evidence chains, confidence/ignorance levels, warnings) for any answers. Control for model or agent belligerence (e.g., sycophancy, deception).

1. **Map Use-Cases to Risk Categories** (e.g., low, moderate, high) by quantifying threats, vulnerabilities, and consequences.
2. **Create Model-Cards** expressing data, training, tuning, parameters, evaluation, limitations, and failure mitigation.
3. **Secure Data:** Conduct a Data-Privacy Review to identify and verify lawful basis for any personal data in the training set. Apply “right to be forgotten” mechanisms to delete individuals’ data from the model. Comply with export control and classify model under the appropriate export-control schedule, file licensing applications if needed, and implement geofencing or API-access restrictions for sanctioned regions.
4. **Minimize Bias:** Diversify data, document initial and annual bias assessment/audits using established toolkits (e.g., IBM AI Fairness 360, Microsoft Fairlearn, Google [2024] Fairness Indicators). For high-risk uses, consider external third-party audit.
5. **Reduce Brittleness:** Minimize errors and hallucination, ground models in authoritative sources, employ guardrails
6. **Reduce Baroqueness:** Disclose AI output with unambiguous marking consistent w/local statutes (e.g., “Generated by an AI language model”), provide explanations (e.g., reasoning paths/evidence chains, confidence/ignorance levels, warnings) and control for belligerence (e.g., sycophancy, deception by agents or robots).
7. **Establish Incident-Response & Monitoring:** Log all user interactions, set up alerts for disallowed content generation, maintain remediation plans (e.g., content takedown, user notifications), measure risk empirically, and employ human oversight for high risk use cases.
8. **Insurance & Liability Protection:** Pursue AI-risk coverage; align policy terms with necessary regulatory regime(s)
9. **Continuous Education:** Subscribe to regulator newsletters (e.g., EU-AI-Watch, FTC AI bulletin, CAC releases). Participate in industry consortia (e.g., Partnership on AI, Future of Life Institute) that track regulations.

Figure 11. Generative AI Vulnerability Mitigations Strategy

Establish a continuous incident-response and monitoring process: log every user interaction, set up real-time alerts for disallowed content generation, and maintain a remediation playbook that includes content takedown, user notification, and regulatory reporting. Ensure human oversight for high risk (e.g., life critical, very high cost of failure) applications.

Because best-effort controls can fail, procure AI-risk insurance that aligns with the relevant regulatory regime (e.g., coverage for GDPR [2016] related fines, UK consumer-product liability, or Australian ACCC penalties). Finally, ensure human oversight and keep the organization security-aware and regulation-aware through ongoing education, participation in industry consortia, and tracking of threat actors who intend to exploit AI systems [MITRE 2023]. Continuous learning, technical controls and a documented, risk-tiered governance framework can make proactive protection a competitive advantage.

7 Future Directions

Organizations will need to track risks of LLMs closely as law, regulation, recommended practice, technology and threat continue to rapidly evolve. New threats include more sophisticated attacks exploiting the weaknesses of AI systems to undermine their confidentiality, integrity and availability, imposing new harms. Conversely, (human and machine) adversaries can use those AI systems as tools to attack organizations at speed and scale to cause harms. For example, adversaries can masquerade with high fidelity deep fakes to gain access and reveal protected information, corrupt third party information to undermine integrity or reputation, or flood a service with deep fakes to deny access to protected groups.

While this paper offers specific mitigations for example legal and regulatory requirements (e.g., privacy and copyright protection), future research by licensed legal/technical experts is required to address legal risks in particular jurisdictions. This could include, for example, comparing national or regional laws (e.g., GDPR Art. 17 vs. US sectoral privacy laws, US Copyright Act § 106A, EU AI Act risk-based obligations) and analyzing how mitigation choices (e.g., data-licensing, watermarking) map into specific statutory or regulatory requirements or exemptions.

Another important category of future risk is the rapidly growing number of AI agents that grow in capability and with increasing levels of delegated authority. Governance across use cases must include specification of agent levels of responsibility and authority and required human awareness and consultation. An important aspect of risk management are controls on agent goals, their access to and use of confidential data, tools, and (financial and human) resources, restricting their ability to make (e.g., high risk) decisions or actions that are inherently human, as well as escalation of high risks to human authorities. In addition, research is required into robust security and resilience controls on Model Context Protocol (MCP) access to other agents as well as tools to discover “shadow AI” [IBM 2026]. Risk management should anticipate human or agent jail-breaking to subvert limitations (e.g., convincing perhaps unwitting humans to escalate privileges) or outright deception, destruction, or misuse and employ safeguards. New adversarial

threats to agentic AI systems target agent APIs, prompt infiltration and obfuscation, credential harvesting, data poisoning and clickbait [MITRE 2025].

As higher level cognitive reasoning and planning develop, research should explore systems that are goal-based which can be infused with a deeper understanding of competence and ignorance, behavioral boundaries, as well as ethical guidelines to increase the likelihood of beneficent behavior. In conclusion, responsible deployment of AI must respect laws, regulations, threat vectors, technical realities, and human limitations to advance human trust and advance the full promise of augmented (human) intelligence.

References

- [AIDA 2022] Artificial Intelligence and Data Act (AIDA), Canada, 2022.
- [Albergotti 2023] Reed Albergotti. “Secret history of Elon Musk, Sam Altman, and OpenAI.” *Semafor*, 24 Mar 2023.
- [Andriushchenko 2024] Maksym Andriushchenko et al. “Jail-breaking leading safety-aligned LLMs with simple adaptive attacks.” arXiv abs/2404.02151, 2024.
- [Anthropic 2025] Anthropic Threat Intelligence Team, “Disrupting the first reported AI-orchestrated cyber espionage campaign,” Nov. 13, 2025.
- [Australia 2024] Dept. of Industry, Science & Resources, Australia. *Voluntary AI Safety Standard*, Canberra, ACT, 5 Sep 2024.
- [Awad et al. 2018] Edmond Awad et al. The Moral Machine Experiment, *Nature*, 563(7729): 59-64, Oct. 2018, doi: 10.1038/s41586-018-0637-6.
- [Bai et al. 2022] Yuntao Bai et al. Constitutional AI: Harmlessness from AI Feedback. *arXiv:2212.08073*. 2022.
- [Bellamy et al. 2018] Rachel Bellamy et al., “AI Fairness 360: An extensible toolkit for detecting and mitigating algorithmic bias,” *IBM Journal of R&D*, 63(4/5):4:1-4:15, 1 Jul-Sept 2019. doi.org/10.1147/jrd.2019.2942287.
- [Bird et al. 2020] Sarah Bird et al., “Fairlearn: A Toolkit for Assessing and Improving Fairness in AI.” Microsoft Research Technical Report MSR TR 2020-32, May 2020.
- [Blackburn 2025] U.S. Senator Marsha Blackburn. “Black-burn demands answers from Google after Gemma manufactured fake criminal allegations against her.” 31 Oct 2025.
- [Bubeck et al. 2023] Sébastien Bubeck et al., “Sparks of Artificial General Intelligence: Early Experiments with GPT-4.” arXiv abs/2303.12712, 2023.
- [Carlini et al. 2023] Nicholas Carlini et al. Extracting Training Data from Large Language Models. In Proceedings of the USENIX Security Symposium, pp. 1234–1249, 2023.
- [Chen and Magramo 2024] Heather Chen and Kathleen Magramo, “Finance worker pays out \$25 million after video call with deepfake ‘chief financial officer’,” CNN. February 4, 2024. www.cnn.com/2024/02/04/asia/deepfake-cfo-scam-hong-kong-intl-hnk/index.html
- [Chevrolet 2023] “Incident 622: Chevrolet dealer chatbot agrees to sell Tahoe for \$1,” *AI Incident Database*, 2023.
- [Kelley 2009] Patrick Gage Kelley et al. “A ‘Nutrition label’ for privacy.” In *Proceedings of the 5th Symposium on Usable Privacy and Security*, Mountain View, CA, 1-12, 15 Jul 2009.
- [Doss et al. 2023] Christopher Doss et al. Deepfakes and scientific knowledge dissemination. *Scientific Reports* 13, 13429 (2023). doi.org/10.1038/s41598-023-39944-3
- [GDPR 2016] European Union. *General Data Protection Regulation* (Regulation (EU) 2016/679), Official Journal L 119, pp. 188-, 4 May 2016.
- [Gerken 2023] Tom Gerken. “ChatGPT: Mayor starts legal bid over false bribery claim.” *BBC*, 6 Apr 2023.
- [GitHub 2025] GitHub Hallucination Leaderboard. 2025.
- [Google 2024] Fairness Indicators: Scalable Infrastructure for Fair ML Systems. www.tensorflow.org/responsible_ai/fairness_indicators/guide. 2024.
- [Guo 2024] Taicheng Guo et al., “Large Language Model Based Multi-agents: A Survey of Progress and Challenges.” *IJCAI* 2024, arXiv 2402.01680.
- [IBM 2026] Scale trusted AI with watsonx.governance. 2026. www.ibm.com/products/watsonx-governance
- [Keller, 2021]. John Keller. Lockheed Martin to develop AI to detect and analyze media disinformation. *Military & Aerospace Electronics*, March 2021. www.darpa.mil/research/programs/semantic-forensics
- [Maybury 2025] Mark Maybury. “Mitigating biased, brittle and baroque generative AI.” In *Proc. of IEEE ICAD*, Tufts Univ., Medford, MA, 24 Jun 2025.
- [McIlroy-Rowe et al. 2024] David McIlroy-Rowe et al., “AI Incident Response Playbooks”, Proceedings of the 31st ACM Conference on Computer and Communications Security, pp. 1123–113, 2024.
- [MCP 2025] David S. Parra, D. S. and Justin Spahr-Summers, 2025. *Model Context Protocol Specification*. Anthropic. modelcontextprotocol.io.
- [MITRE 2023] MITRE. *Adversarial Threat Landscape for AI Systems (ATLAS)*, 2023.
- [MITRE 2025] MITRE ATLAS December 2025 Update. Available at: atlas.mitre.org/resources/updates/2025-12.
- [MITRE 2026] Common Vulnerabilities and Exposures (CVE). The MITRE Corporation. www.cve.org.
- [Mobley 2025] Mobley v. Workday, Inc., No. 3:23 cv 00770, N.D. Cal. (2025).
- [Mousavi et al. 2023] Sajad Mousavi et al. Enhancing Large Language Models with Ensemble of Critics for Mitigating Toxicity and Hallucination. Neurips 2023. neurips.cc/virtual/2023/76724
- [NIST 2023] National Institute of Standards and Technology. *AI Risk Management Framework (AI RMF): A Public Draft*, Gaithersburg, MD, 26 Jan 2023.
- [NIST 2024] NIST Trustworthy and Responsible AI NIST AI 600-1 Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile. July 2024.

- [Ortutay 2025] Barbara Ortutay. Judge approves \$1.5 billion copyright settlement between AI company Anthropic and authors. *Associated Press*, September 2025.
- [Patil et al. 2023] Rishav Patil et al. DP BERT: Differentially Private Pre-training of Language Models. In *Proceedings of the 40th International Conference on Machine Learning*, pp. 27246–27271. arxiv.org/abs/2108.01624. PMLR, 2023.
- [PEARL 2025] AstrisAI. “PEARL: Persistent Environment for AI, Readiness, and Learning,” Lockheed Martin Astris AI, 2025. astrisai.com/for-government.
- [Phuong 2024] Mary Phuong et al., “Evaluating frontier models for dangerous capabilities.” *arXiv abs/2403.13793*, 2024.
- [ShadowRay 2025] ShadowRay 2.0: Active Global Campaign Hijacks Ray AI into Self-Propagating Botnet. *Oligo Security*, November 2025. www.oligo.security/blog/shadowray-2-0-attackers-turn-ai-against-itself-in-global-campaign-that-hijacks-ai-into-self-propagating-botnet
- [Starbuck 2025] Starbuck v. Meta Platforms, Inc., No. 2024 CV 05678, E.D. Va. (29 Apr 2025).
- [Strom et al. 2020] Blake Strom et al. 2020. MITRE ATT&CK®: Design and Philosophy. Technical report, The MITRE Corporation. See also attack.mitre.org.
- [Sivashanmugam 2025] Sivashanmugam, Sathesh P. “Model Inversion Attacks on Llama 3: Extracting PII from Large Language Models.” *arXiv preprint arXiv:2507.04478*, 2025.
- [Sysdig 2024] Sysdig Threat Research Team. LLMjacking: Stolen Cloud Credentials Used in New AI Attack. *Sysdig Research*, May 2024. www.sysdig.com/blog/llmjacking-stolen-cloud-credentials-used-in-new-ai-attack
- [UK 2023] HM Government, United Kingdom. *AI Regulation: A Pro-Innovation Approach* (White Paper), 2023.
- [Wang et al. 2022] Xuezhi Wang et al. 2023. Self-Consistency Improves Chain of Thought Reasoning in Language Models. In *Proceedings of the 11th International Conference on Learning Representations (ICLR 2023)*. arxiv.org/abs/2203.11171.
- [Wang et al. 2025] Shenao Wang et al. 2025. Large Language Model Supply Chain: A Research Agenda. *ACM Trans. Softw. Eng. Methodol.* 34(5) Article 147. June 2025. doi.org/10.1145/3708531
- [X Corp 2025] X Corp et al. v. Apple Inc. et al., No. 4:25 cv 00914, N.D. Tex. (2025).
- [Zhang et al. 2023] S. Zhang et al., “Self-Check: Using LLMs to Detect Their Own Hallucinations”, *NeurIPS* 2023.
- [Zhou et al. 2024] Xiangyu Zhou et al., “Learning to poison large language models during instruction tuning.” Wayne State and Univ. of Michigan, *arXiv abs/2402.13459v1*, 2024

Acknowledgments

This research benefited from the Lockheed Martin AI Center (LAIC), AstrisAI (astrisai.com), the Advanced Cybersecurity Center (acscenter.org), and work with Marc Zissman (MIT Lincoln Lab) on confidentiality, integrity and availability in AI. I am grateful for detailed feedback from Jason Johnson, Michael Harasimowicz, Mike Koelemay, Robbie Mandlebaum, Ambrose Kam as well as Mike Baylor, Greg Forrest, James Droskoxi, Vivek Nagaraj, Pasquali, Steeve Payne and expertise from Arlanda Johnson, Adriana Luedke, Rajan Mehndiratta, Andrzej Banaszuk, Irene Helley, and Amanda Fitting.

